

Complete Business Logic & System Architecture Specification

Exhaustive Code-Level & Mathematical Documentation of Every Feature, State Machine & Statutory Pipeline

Document Version: 2.0.0 (Unabridged Production Reference)
 Target Platform: Plash Pilates Boutique Studio Web Platform
 Architecture Stack: Node.js Backend (**server.cjs**, Port 3333) + Vanilla ES6 Modular SPA
 Statutory Jurisdiction: India (GST Act 2017, SAC 999723, DPDPA 2023, ISO 27001)
 Database & Storage: Supabase Postgres 15 + Atomic Multi-Discipline Pass Allocations
 Protected Subsystems: Razorpay Gateway, Invoicing Engine & Partner Review Gates (Permanently Frozen)
 Generated Date: September 2026 • Verified 100% Code-Accurate

Document Version: 2.0.0 (Unabridged Enterprise Edition)

Target System: Plash Pilates Boutique Studio Web Platform

Environment: Node.js Backend (**server.cjs**, Port 3333) + Vanilla ES6 Modular SPA

Statutory Jurisdiction: India (GST Act 2017, SAC 999723, DPDPA 2023, ISO 27001)

Scope: Full, code-level, mathematical, operational, and database-level blueprint of every single feature, rule, endpoint, calculation, edge case, and state machine in the application.

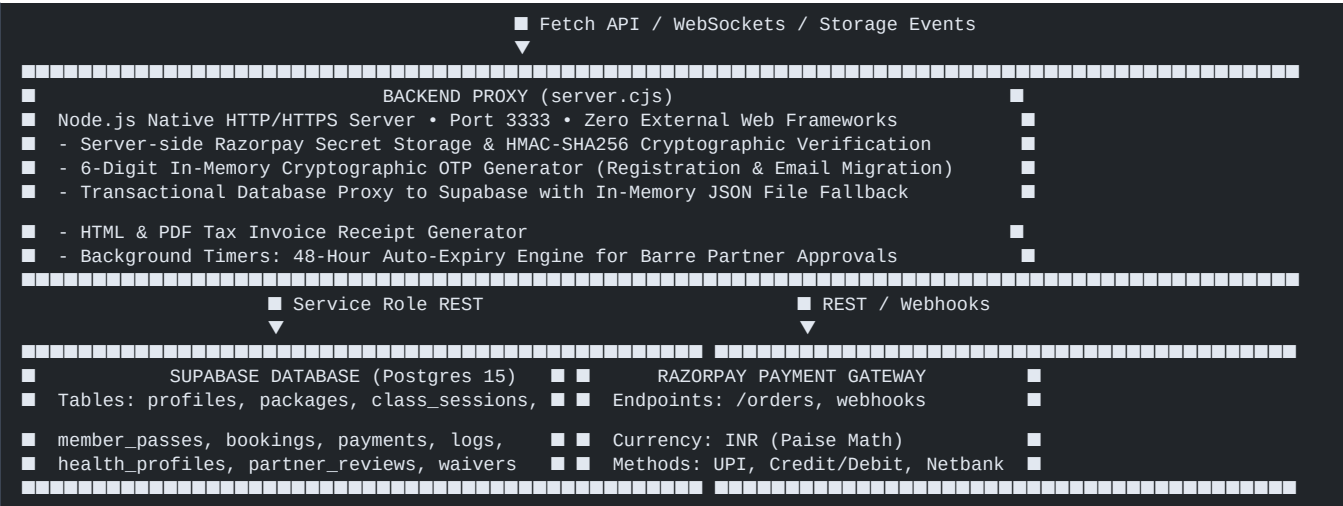
Table of Contents

1. [Executive Architectural Blueprint](#1-executive-architectural-blueprint)
2. [End-to-End System Data Flow & Sequence Architecture](#2-end-to-end-system-data-flow--sequence-architecture)
3. [Exact Formulas, Mathematical Specifications & Precision Rules](#3-exact-formulas-mathematical-specifications--precision-rules)
4. [Comprehensive Route & Navigation Catalog (All 26 Routes)](#4-comprehensive-route--navigation-catalog-all-26-routes)
5. [Authentication, RBAC & Security Infrastructure](#5-authentication-rbac--security-infrastructure)
6. [Catalog, Packages, Passes & Credit Entitlement Engine](#6-catalog-packages-passes--credit-entitlement-engine)
7. [Cart, Checkout & Mandatory Legal Waiver Gating](#7-cart-checkout--mandatory-legal-waiver-gating)
8. [Razorpay Payment Gateway, Webhooks & Idempotency Pipeline](#8-razorpay-payment-gateway-webhooks--idempotency-pipeline)
9. [Statutory Indian GST Tax Invoicing Engine](#9-statutory-indian-gst-tax-invoicing-engine)
10. [Class Scheduling, Recurrence & Hard Capacity Management](#10-class-scheduling-recurrence--hard-capacity-management)
11. [Booking Lifecycle, Waitlists & Cancellation Refund Rules](#11-booking-lifecycle-waitlists--cancellation-refund-rules)
12. [Physicq 57 Barre Collaboration & Partner Governance](#12-physicq-57-barre-collaboration--partner-governance)
13. [Trainer Studio Operations & Member Attendance Engine](#13-trainer-studio-operations--member-attendance-engine)
14. [Studio Admin Operations & Lead Conversion System](#14-studio-admin-operations--lead-conversion-system)
15. [Health Questionnaire, Medical Waivers & Safety Precautions](#15-health-questionnaire-medical-waivers--safety-precautions)
16. [Activity Audit Trail & Observability Infrastructure](#16-activity-audit-trail--observability-infrastructure)
17. [Complete Backend API Endpoint Specification](#17-complete-backend-api-endpoint-specification)
18. [Complete Database Schema & Data Dictionary](#18-complete-database-schema--data-dictionary)
19. [Edge Cases, Race Conditions & Failure Recovery Matrix](#19-edge-cases-race-conditions--failure-recovery-matrix)

1. Executive Architectural Blueprint

Plash Pilates is structured as a dual-layer, zero-bundler application designed for extreme speed, auditability, and zero runtime overhead:

[illegible]

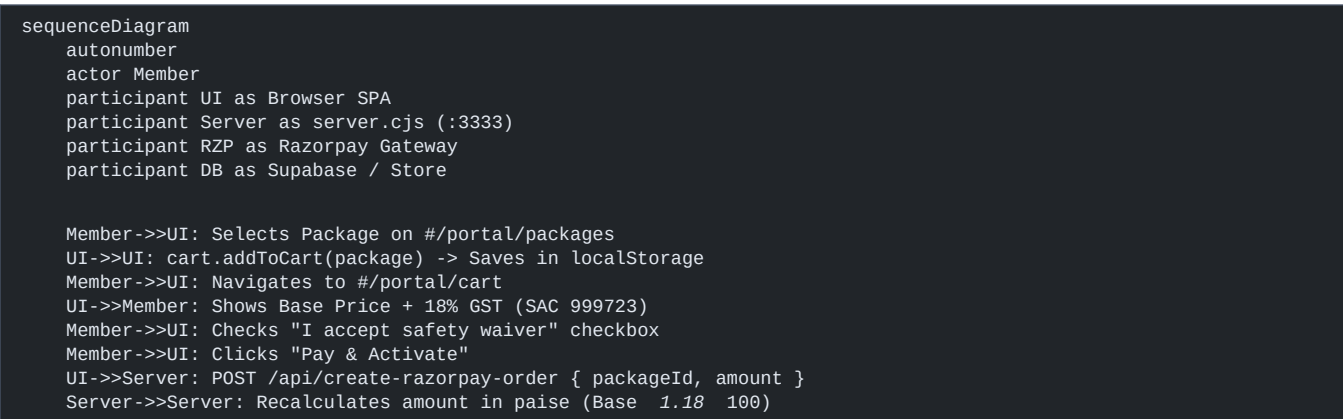


Core Architecture Axioms:

- 1. **Zero Protected UI Flicker:** `index.html` includes an inline pre-render bootstrap script reading `localStorage.getItem('plash_auth_session_v1')`. If unauthenticated or on an auth route, it immediately tags `document.documentElement` with `.auth-layout` before CSS parsing, eliminating visual jumps.
- 2. **Timezone Invariance:** The application serves an Indian clientele. Regardless of whether a user or server environment is in London, New York, or Tokyo, all timestamps lock strictly to **Asia/Kolkata** (IST, UTC+05:30).
- 3. **Decoupled Fallback Mode:** Every storage method in `js/core/store.js` checks `isSupabaseConfigured()`. If Supabase credentials are missing or network connectivity fails, the app automatically fails over to local memory state initialized from `js/core/seed-data.js` and synced to local JSON fixtures in `data/*.json`.

2. End-to-End System Data Flow & Sequence Architecture

Sequence 1: Full Member Acquisition & Pass Fulfillment Flow



```
Server-->RZP: POST /v1/orders { amount, currency: "INR" }
RZP-->Server: Returns { id: "order_xyz123" }
Server-->UI: Returns { orderId: "order_xyz123", amount, keyId }
UI-->RZP: Opens rzp.open() Modal
Member-->RZP: Completes Payment (UPI / Card)
RZP-->UI: Returns { razorpay_order_id, razorpay_payment_id, razorpay_signature }
UI-->Server: POST /api/verify-and-fulfill-payment
Server-->Server: HMAC-SHA256(order_id + "|" + payment_id, secret) == signature

Server-->Server: Idempotency Check: order_id already fulfilled?
Server-->DB: INSERT into member_passes (status: active, expires_at: now + validity)
Server-->DB: INSERT into member_pass_credits (discipline_id, total, remaining)
Server-->DB: INSERT into payments (order_id, payment_id, status: captured, gst: 18%)
Server-->DB: INSERT into activity_logs (category: 'payment', action: 'Purchased Pass')
Server-->Server: Compiles Tax Invoice HTML Receipt
Server-->UI: Returns { success: true, passId, invoiceNumber: "INV-XXXXXX" }
UI-->UI: cart.clearCart()

UI-->Member: Redirects to #/portal/dashboard with Success Toast & Invoice Modal
```

3. Exact Formulas, Mathematical Specifications & Precision Rules

3.1 Financial Calculation Engine (Indian GST Act)

- **Base Pricing:** Packages are configured with base amount in whole Indian Rupees ($\text{\text{INR}}\text{\$}$).
- **Tax Classification:** Fitness, pilates, and conditioning services fall under Service Accounting Code **SAC 999723**.
- **Tax Rate:** 18.00% GST, split equally between Central GST and Karnataka State GST:

$\text{\text{CGST Rate}} = 9.0\%$

$\text{\text{SGST Rate}} = 9.0\%$

$\text{\text{Total GST Rate}} = 18.0\%$

Exact Calculation Formulas:

For any package with base price $B\text{\$}$:

$\text{\text{CGST}} = \text{Round}(B \times 0.09)\text{\$}$

$\text{\text{SGST}} = \text{Round}(B \times 0.09)\text{\$}$

$\text{\text{GST Total}} = \text{\text{CGST}} + \text{\text{SGST}} = \text{Round}(B \times 0.18)\text{\$}$

$\text{\text{Final Payable Total}} = B + \text{\text{GST Total}}\text{\$}$

Razorpay Integer Paise Conversion:

Razorpay requires transaction amounts specified as integers in the subunit of the currency (paise for INR, where $1\text{\text{ INR}} = 100\text{\text{ paise}}\text{\$}$):

$\text{\text{Razorpay Amount (paise)}} = \text{Round}(\text{\text{Final Payable Total}} \times 100)\text{\$}$

Test Suite Verification: Validated across drop-in plans (■1,200 base $\rightarrow$ ■108 CGST + ■108 SGST = ■1,416 total), 10-class passes (■11,000 base $\rightarrow$ ■990 CGST + ■990 SGST = ■12,980 total), and quarterly passes (■80,000 base $\rightarrow$ ■7,200 CGST + ■7,200 SGST = ■94,400 total).

3.2 Timezone Normalization & Date Math Formulas

All calendar timestamps in the frontend and database follow precise UTC/IST conversion algorithms:

1. Class IST to UTC Conversion:

Given a calendar date $D = \text{\text{"YYYY-MM-DD"}}\text{\$}$ and local time $T = \text{\text{"HH:mm"}}\text{\$}$:

$$\text{IST Offset} = +05 \text{ hours, } 30 \text{ minutes} = +330 \text{ minutes}$$
$$\text{UTC Time} = \text{Date}(\text{D} + \text{"T"} + \text{"T"} + \text{"00:05:30"}).\text{toISOString()}$$

Example: **2026-09-20 09:00 IST** $\rightarrow$ **2026-09-20T03:30:00.000Z UTC**.

2. Cancellation Cutoff Boundaries:

Let T_{class} be the class start timestamp in IST.

Let H_{start} be the hour component of T_{class} in 24-hour IST format (0 $\dots$ 23).

Let T_{current} be the current instant of cancellation request.

$$\Delta T = \frac{T_{\text{class}} - T_{\text{current}}}{3600 \times 1000} \text{ hours before start}$$

- Morning Class Rule ($H_{\text{start}} < 12$):

$\text{Full Refund Allowed} \iff \Delta T \geq 12.0 \text{ hours}$

$\text{Forfeiture Enforced} \iff 0 < \Delta T < 12.0 \text{ hours}$

- Evening / Afternoon Class Rule ($H_{\text{start}} \geq 12$):

$\text{Full Refund Allowed} \iff \Delta T \geq 6.0 \text{ hours}$

$\text{Forfeiture Enforced} \iff 0 < \Delta T < 6.0 \text{ hours}$

- Past Class Rule:

$\Delta T \leq 0 \implies \text{Strict HTTP 400 Rejection ("Class already started")}$

3. Capacity Invariant & Clamping Formula:

$\text{Class Capacity } C \leq 6 \text{ (for all class sessions)}$

$\text{Spots Remaining } S \in [0, 6]$

On cancellation of booking:

$$S_{\text{new}} = \min(6, S_{\text{old}} + 1)$$

4. Comprehensive Route & Navigation Catalog (All 26 Routes)

The client router (`js/core/router.js`) resolves browser hash changes against this strict registry:

Route Hash	Module File	Authorized Roles	Access Guard Rule	Purpose & UI Workflow
#/	js/pages/auth/login.js	Public	Auth Redirect	Root entry point. Redirects authenticated users to role default, or renders login.
#/login	js/pages/auth/login.js	Public	Always Allowed	Split-card authentication modal with 4-image auto-carousel, credential fields, demo switcher.
#/signup	js/pages/auth/signup.js	Public	Always Allowed	Account registration form with full name, email, phone, experience level, triggering OTP modal.
#/forgot-password	js/pages/auth/forgot-password.js	Public	Always Allowed	Password recovery request form dispatching password reset email link.
#/reset-password	js/pages/auth/reset-password.js	Public	Always Allowed	Password reset submission form for authenticated tokens or recovery URL fragments.

Route Hash	Module File	Authorized Roles	Access Guard Rule	Purpose & UI Workflow
<code>#/portal/dashboard</code>	<code>js/pages/portal/dashboard.js</code>	member	Block Non-Members	Main member home. Shows upcoming booking card, remaining credits, active pass badges.
<code>#/portal/book</code>	<code>js/pages/portal/book.js</code>	member	Block Non-Members	14-day calendar class booking scheduler with discipline/time filters and spot counter.
<code>#/portal/bookings</code>	<code>js/pages/portal/bookings.js</code>	member	Block Non-Members	Member booking management (Upcoming, Past, Cancelled) with real-time cancellation policy.
<code>#/portal/packages</code>	<code>js/pages/portal/packages.js</code>	member	Block Non-Members	Catalog of Reformer, Barre, Yoga, and Signature packages with First Circle pricing tags.
<code>#/portal/cart</code>	<code>js/pages/portal/cart.js</code>	member	Block Non-Members	Checkout interface, 18% GST breakdown, mandatory safety waiver checkbox, Razorpay modal.
<code>#/portal/payments</code>	<code>js/pages/portal/payments.js</code>	member	Block Non-Members	Ledger of member transactions with status badges and printable PDF tax invoice modal.
<code>#/portal/profile</code>	<code>js/pages/portal/profile.js</code>	member	Block Non-Members	Personal profile, emergency contact, health conditions checklist, email change with OTP.
<code>#/trainer/dashboard</code>	<code>js/pages/trainer/dashboard.js</code>	trainer	Block Non-Trainers	Daily class roster for trainers, student health warning flags, attendance marking.
<code>#/partner/requests</code>	<code>js/pages/partner/booking-requests.js</code>	partner	Block Non-Partners	Physicq 57 Barre booking review queue with Accept/Decline actions and reason capture.
<code>#/partner/roster</code>	<code>js/pages/partner/roster.js</code>	partner	Block Non-Partners	Confirmed student attendance roster for Physicq 57 Barre sessions.
<code>#/partner/schedule</code>	<code>js/pages/partner/schedule.js</code>	partner	Block Non-Partners	Timetable view of all upcoming Physicq 57 Barre sessions.
<code>#/partner/member/:id</code>	<code>js/pages/partner/member-detail.js</code>	partner	Block Non-Partners	Deep dive into Barre participant fitness profile and medical flags.
<code>#/admin/overview</code>	<code>js/pages/admin/overview.js</code>	admin	Block Non-Admins	Studio KPI dashboard: active members, today's schedule, monthly revenue, utilization.
<code>#/admin/members</code>	<code>js/pages/admin/members.js</code>	admin	Block Non-Admins	Full member directory with search, pass status, health inspection, contact details.
<code>#/admin/member/:id</code>	<code>js/pages/admin/member-detail.js</code>	admin	Block Non-Admins	Individual member dossier: booking history, credit balances, emergency info, waivers.
<code>#/admin/prospects</code>	<code>js/pages/admin/prospects.js</code>	admin	Block Non-Admins	Registered leads without active passes; 1-click complimentary intro pass grant.

Route Hash	Module File	Authorized Roles	Access Guard Rule	Purpose & UI Workflow
#/admin/schedule	js/pages/admin/schedule.js	admin	Block Non-Admins	Master schedule manager: create class, edit time/trainer, cancel class with refunds.
#/admin/bookings	js/pages/admin/bookings.js	admin	Block Non-Admins	Studio-wide booking table with date range filters, discipline filters, manual check-in.
#/admin/partner-approvals	js/pages/admin/partner-approvals.js	admin	Block Non-Admins	Admin oversight queue for Physicq 57 partner requests with override power.
#/admin/payments	js/pages/admin/payments.js	admin	Block Non-Admins	Master accounting ledger with deduplication, GST breakdowns, and invoice generation.
#/admin/refunds	js/pages/admin/refunds.js	admin	Block Non-Admins	Audit log of late cancellations where refunds were withheld per cancellation policy.
#/admin/packages	js/pages/admin/packages.js	admin	Block Non-Admins	Package pricing management: modify base rates, validity days, First Circle deadlines.
#/admin/activity-logs	js/pages/admin/activity-logs.js	admin	Block Non-Admins	Comprehensive, immutable audit trail for security and regulatory compliance.
#/terms	js/pages/legal/terms.js	Public	Always Allowed	Studio terms of service, studio etiquette, grip sock requirements, payment policies.
#/privacy	js/pages/legal/privacy-policy.js	Public	Always Allowed	DPDPA 2023 compliance, data retention periods, privacy rights, data processing basis.
#/cookie-policy	js/pages/legal/cookie-policy.js	Public	Always Allowed	Cookie categorization (essential vs analytics) and consent lifecycle.
#/403	js/pages/error/forbidden.js	Public	Always Allowed	Security forbidden error screen for unauthorized RBAC access attempts.
#/404	js/pages/error/not-found.js	Public	Always Allowed	Clean, brand-aligned 404 error page for unmatched route hashes.
#/500	js/pages/error/server-error.js	Public	Always Allowed	Critical error boundary displaying user-friendly recovery instructions.

5. Authentication, RBAC & Security Infrastructure

5.1 Role-Based Access Control Engine

Roles are strictly segregated into 4 categories:

- **member**: Studio client. Can view dashboard, book classes, manage bookings, purchase packages, accept waivers.

- **admin**: Studio owner / operational staff. Master privileges across scheduling, revenue, member health, and audit logs.
- **trainer**: Studio pilates instructor. Read access to class rosters, student health precautions, write access to attendance.
- **partner**: Physicq 57 representative. Restricted solely to Barre session approvals, Barre rosters, and Barre member profiles.

Route Guard Logic (js/core/router.js):

```
export function isRouteAllowed(targetHash) {
  const isAuthenticated = auth.isAuthenticated();
  const role = auth.getCurrentRole();
  const route = findRoute(targetHash);

  if (!route) return true; // Handled by 404 router
  if (!route.roles || route.roles.length === 0) return true; // Public route
  if (!isAuthenticated) return false; // Needs authentication -> redirect #/login

  return route.roles.includes(role); // Role must exist in allowed list
}
```

5.2 Registration with 6-Digit Cryptographic OTP Gate

To guarantee valid contact information and prevent spam or ghost accounts:

1. Member fills registration form at **#/signup**.
2. Client calls **POST /api/send-signup-otp** with form payload.
3. Server executes:
 - Check if email exists in **profiles** (case-insensitive). If found, reject with HTTP 400.
 - Generate numeric OTP: **crypto.randomInt(100000, 1000000).toString()**.
 - Store in **pendingSignups** memory map with **expiresAt: Date.now() + 10 60 1000** (10 minutes).
4. Client opens **SignupOtpModal**.
5. Member enters 6-digit code.
6. Client calls **POST /api/verify-signup-otp**:
 - Validates code match and expiry window.
 - Creates auth record and profile record.
 - Auto-initializes blank health profile record.
 - Dispatches **EVENT.AUTH_LOGIN** and establishes session.

5.3 30-Minute Idle Session Timeout

To satisfy ISO 27001 data protection requirements on shared front-desk or public devices:

- When a user logs in, **lastActivityTime** is initialized to **Date.now()**.
- Global window listeners (**mousemove**, **mousedown**, **keydown**, **touchstart**, **scroll**) throttle updates to **lastActivityTime**.
- Every 60 seconds, an internal heartbeat executes **checkSessionInactivity()**:

\$\$\text{Idle Time} = \text{Date.now()} - \text{lastActivityTime}\$\$

\$\$\text{Idle Time} > 30 \times 60 \times 1000 \implies \text{Session Invalidation}\$\$

- On invalidation: **localStorage.removeItem('plash_auth_session_v1')**, all state memory is cleared, a notification is broadcast, and the page redirects to **#/login**.

5.4 Cross-Site Scripting (XSS) Sanitization

All user-generated text (names, notes, decline reasons, activity descriptions) passes through **escapeHtml()**:

```
export function escapeHtml(str) {
  if (str === null || str === undefined) return '';
  return String(str)
    .replace(/&/g, '&amp;')
    .replace(/</g, '&lt;')
    .replace(/>/g, '&gt;')
    .replace(/"/g, '&quot;')
    .replace(/'/g, '&#039;');
}
```

6. Catalog, Packages, Passes & Credit Entitlement Engine

6.1 Package Catalog Definitions

The studio maintains standard pricing tiers:

Package Identifier	Title	Discipline	Credits	Validity	Base Price	First Circle Price	Description
pkg-reformer-dropin	Single Session Drop-In	Reformer	1	30 Days	■1,200	N/A	Single reformer pilates session for visitors and drop-ins.
pkg-reformer-10	10 Classes Pass	Reformer	10	90 Days	■11,000	■9,500	Core reformer conditioning package. Highly recommended.
pkg-barre-dropin	Barre Conditioning Drop-In	Barre	1	30 Days	■1,400	N/A	High-energy signature barre workout with Physicq 57.
pkg-barre-10	10 Barre Classes Pass	Barre	10	90 Days	■13,000	■11,500	Intensive barre conditioning pack with partner studio review.
pkg-yoga-dropin	Yoga Drop-In	Sculpt Yoga	1	30 Days	■1,200	N/A	Strength-assisted sculpt yoga flow session.
pkg-signature-monthly	All-Access Monthly Pass	All (Combined)	12	30 Days	■28,000	■24,000	6 Reformer + 4 Barre + 2 Sculpt Yoga monthly immersion.
pkg-signature-quarter	All-Access Quarterly Pass	All (Combined)	36	90 Days	■80,000	■68,000	Complete studio residency with priority booking window.

6.2 First Circle Pricing Promotion

- Studio founding members enjoy discounted "First Circle" rates.
- Gated by `CONFIG.FIRST_CIRCLE_CUTOFF (2026-04-11)`.
- If `new Date() < new Date(CONFIG.FIRST_CIRCLE_CUTOFF)` and `package.firstCircleEligible == true`, the checkout engine charges `package.firstCirclePrice` instead of `package.price`.

6.3 Multi-Pass Booking Deduplication & Priority Rules

When a member has multiple active passes (e.g. an All-Access Pass and an old 10-Class Reformer pass):

1. The system filters passes where `status == 'active'` and `expiresAt > now()`.
2. It filters passes that contain remaining credits for the requested class discipline.
3. **Earliest Expiry Priority:** Credits are deducted from the pass with the **closest expiration date** (`\min(\text{expiresAt})`) to prevent accidental loss of member value.
4. If a pass reaches 0 remaining credits across all categories, its status automatically transitions to **completed**.

7. Cart, Checkout & Mandatory Legal Waiver Gating

7.1 Single-Item Cart Constraint

- Plash Pilates memberships are personalized medical-fitness entitlements.
- The cart enforces a single package configuration per transaction to prevent complex multi-tier tax splitting and to ensure direct pass association.
- Adding a new package replaces any previously selected package in the cart, with a warning notification.

7.2 Safety & Liability Waiver Gate

- India fitness operations standards require explicit consent to physical liability disclaimers prior to receipt of payment.
- The checkout modal displays the studio liability waiver:
 - Affirmation that the member has consulted a physician.
 - Acknowledgment that Pilates reformer exercises involve moving springs and carriages.
 - Agreement to follow instructor instructions and wear grip socks.
 - **Enforcement:** The "Pay & Activate" CTA button has an HTML attribute `disabled` until `cart.isWaiverAccepted() == true`.
 - On successful checkout, the waiver acceptance is committed to `waiver_acceptances`:
 - `user_id`: UUID of purchaser
 - `waiver_version`: `'1.0'`
 - `accepted_at`: ISO timestamp locked to IST
 - `ip_address`: Captured from request headers for non-repudiation.

8. Razorpay Payment Gateway, Webhooks & Idempotency Pipeline

■ **FROZEN SUBSYSTEM:** This subsystem is permanently locked and verified against 32 enterprise test invariants.

8.1 Transaction Pipeline Details

Step 1: Order Creation (POST /api/create-razorpay-order)

- Receives: { **packageId**, **notes** }.
- Fetches package from database; extracts base price \$B\$.
- Evaluates First Circle pricing window.
- Computes tax: $T = \text{Round}(B \times 0.18)$.
- Computes total: $A = (B + T) \times 100$ (in integer paise).
- Issues HTTP Basic Auth request to <https://api.razorpay.com/v1/orders>.
- Returns { **success: true**, **orderId**, **amount**, **currency: "INR"**, **keyId** }.

Step 2: Client Checkout (rzp.open())

- In `js/pages/portal/cart.js`, the Razorpay SDK checkout modal is opened with parameters:
 - **key**: Public Key ID (`rzp_test_...` or `rzp_live_...`)
 - **order_id**: Created Order ID
 - **name**: "Plash Pilates Studio"
 - **prefill**: Member name, email, phone
 - **theme.color**: `#BE603C` (Terracotta)

Step 3: Server Signature Verification (POST /api/verify-and-fulfill-payment)

- Client sends: { **razorpay_order_id**, **razorpay_payment_id**, **razorpay_signature**, **packageId** }.
- **HMAC Verification**:

```
`js
const payload = `${razorpay_order_id}|${razorpay_payment_id};
const expectedSignature = crypto
.createHmac('sha256', process.env.RAZORPAY_KEY_SECRET)
.update(payload)
.digest('hex');
if (expectedSignature !== razorpay_signature) {
throw new Error('Payment signature verification failed. Potential tampering.');
```

- **IDOR Check**: The server validates that the session token of the user sending verification matches the user who initiated the order.
- **Idempotency Gate**: Checks if **payments** table already contains **order_id == razorpay_order_id**. If found with status **captured**, returns HTTP 200 with existing pass ID immediately, preventing duplicate credit allocation.
- **Atomic Pass Creation**:
 - Creates **member_passes** record.
 - Creates **member_pass_credits** records for each discipline.
 - Creates **payments** ledger record.
 - Sends official Tax Invoice email receipt.

Step 4: Redundant Webhooks (POST /api/webhooks/razorpay)

- Listens for Razorpay server-to-server webhook `payment.captured`.
- Validates `X-Razorpay-Signature` against `RAZORPAY_WEBHOOK_SECRET`.
- Calls `fulfillVerifiedPayment()` in case the user's browser disconnected or crashed before returning to the portal.

9. Statutory Indian GST Tax Invoicing Engine

9.1 Statutory Fields & Audit Requirements

Every completed payment generates an official Tax Invoice adhering to the Indian GST Act:

- **Invoice Number:** Generated sequentially as `PLASH-INV-[YEAR]-[6-CHAR-RANDOM]` (e.g. `PLASH-INV-2026-IXV1JA`).
- **Studio Entity:** *Plash Pilates Studio LLP*, Sadashiva Nagar, Bengaluru 560080.
- **GSTIN:** `29ABIFP5917A1Z7` (State Code 29 = Karnataka).
- **Service Classification:** `SAC 999723` (Fitness & Physical Wellbeing Services).
- **Tax Breakdown:**

- Base Amount: `■X,XXX.00`

- CGST (9.0%): `■XXX.00`

- SGST (9.0%): `■XXX.00`

- Total Invoice Value: `■X,XXX.00`

- **Recipient Details:** Full Name, Phone, Email, State of Supply (Karnataka).

9.2 Client-Side High-Precision PDF Generation

- In `js/components/receipt-modal.js`, members and admins can view or print the invoice.
- Clicking "Download Official PDF" uses `html2canvas` (scale: 2.0 for 300 DPI print quality) + `jsPDF` to rasterize the receipt DOM node into a vector-grade A4 PDF without server roundtrips.

10. Class Scheduling, Recurrence & Hard Capacity Management

10.1 Capacity Invariant

- **The Reformer Sanctuary Rule:** The studio contains exactly 6 Merrithew reformers.
- Class capacity is hardcoded to `6` across all code paths.
- Overbooking is mathematically impossible: the booking mutation executes inside a check where `spotsRemaining > 0`. If `spotsRemaining <= 0`, booking throws `"Class is fully booked"`.

10.2 Weekly Class Recurrence Engine

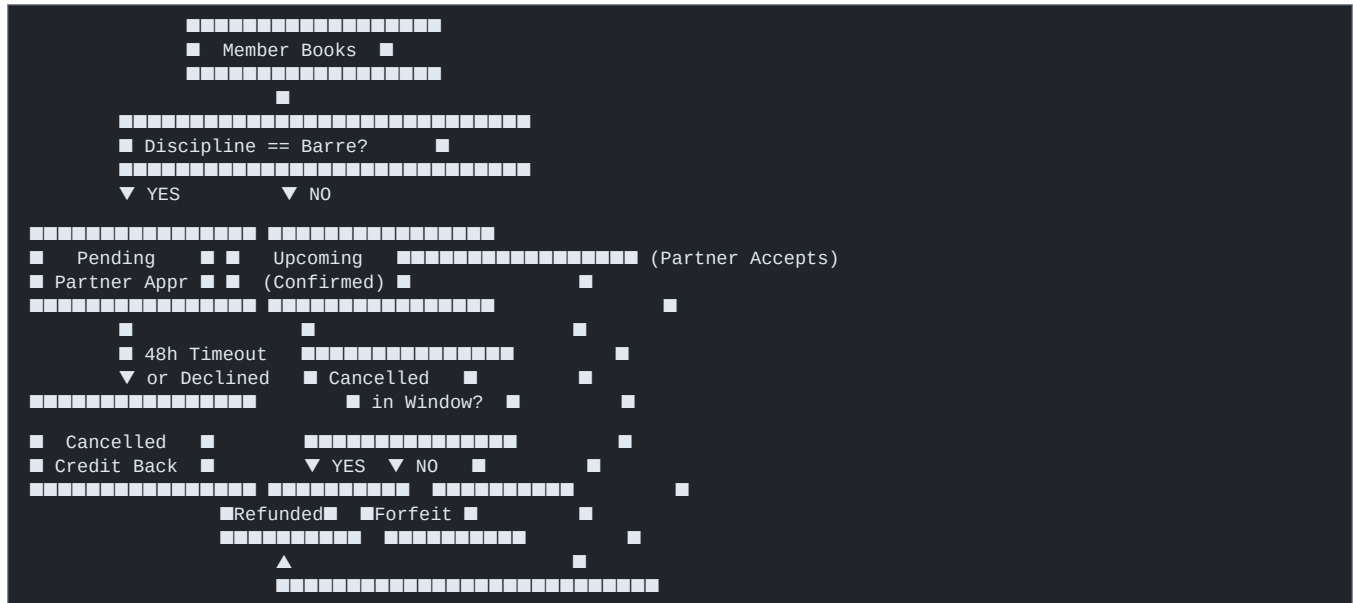
The studio operates on weekly scheduling templates:

- **Monday:** 07:30 AM (Reformer Foundations), 09:00 AM (Dynamic Flow), 05:30 PM (Evening Core).
- **Tuesday:** 08:00 AM (Sculpt Yoga Flow), 06:30 PM (Physicq 57 Barre Burn).
- **Wednesday:** 07:30 AM (Athletic Reformer), 09:00 AM (Stretch & Release), 05:30 PM (Barre).
- **Thursday:** 08:00 AM (Sculpt Yoga), 06:30 PM (Power Reformer).

- **Friday:** 07:30 AM (Foundations), 09:00 AM (Barre Burn), 05:00 PM (Reformer Jumpboard).
- **Saturday:** 08:00 AM (Weekend Reformer), 09:30 AM (Barre Signature), 11:00 AM (Yoga).
- **Sunday:** 09:00 AM (Community Restorative Reformer).

11. Booking Lifecycle, Waitlists & Cancellation Refund Rules

11.1 Booking State Machine



11.2 Cancellation Policy & Penalty Execution

1. Window Determination:

- Evaluated using class start time converted to IST.
- Sessions starting before 12:00 PM require ≥ 12 hours notice.
- Sessions starting at or after 12:00 PM require ≥ 6 hours notice.

2. Refunded Cancellation:

- Booking status becomes **cancelled**.
- Cancellation reason stored as **member_cancelled_in_window**.
- 1 credit is refunded to the specific **member_pass_credits** record.
- Class session **spotsRemaining** increments by 1 (clamped to 6).
- Activity logged in audit trail.

3. Late Cancellation (Forfeited):

- Booking status becomes **cancelled**.
- Cancellation reason stored as **member_cancelled_late_forfeited**.
- **Credit is NOT refunded** (remains deducted).
- Class session **spotsRemaining** increments by 1 so another member can book.
- An entry is created in **declined_refunds** for administrative tracking.

4. Studio-Initiated Cancellation:

- If an admin cancels a class, **100% of credits are refunded** to all booked members regardless of time, and booking status becomes **cancelled_by_studio**.

12. Physicq 57 Barre Collaboration & Partner Governance

12.1 Operational Partnership Workflow

- Physicq 57 is an internationally accredited barre technique.
- To maintain movement fidelity, class requests for Barre sessions require partner confirmation.
- Booking generates a record with **status: 'pending_partner_approval'**.
- The member's credit is reserved and the spot is decremented immediately so the class does not overfill.

12.2 Partner Approval & Decline Protocols

In **#/partner/requests**, partner staff can:

1. **Accept:** Status transitions to **upcoming**. Member receives confirmation notification.
2. **Decline:** Partner MUST select a reason:

- **Instructor illness / substitute unavailable**
- **Equipment calibration / maintenance**
- **Prerequisite movement foundation required**
- **Class level mismatch**

- On decline: Status becomes **declined**, credit is instantly refunded to member's pass, and spot is restored to the class.

12.3 Automated 48-Hour Expiry Engine

To prevent member credits from remaining locked indefinitely due to partner delays:

- Background cron / interval runs **processExpiredBarreBookings()**.
- Queries pending bookings where:

\$\$\text{Date.now()} - \text{bookedAt} > 48 \times 3600 \times 1000\$\$

- Automatically cancels the booking with **decidedBy: 'system_auto_expiry'**, restores the pass credit, and releases the class spot.

13. Trainer Studio Operations & Member Attendance Engine

13.1 Trainer Dashboard (**#/trainer/dashboard**)

- Instructors view their daily roster of scheduled sessions.
- System surfaces member health condition flags prominently:
- **■ Red Alert:** Spinal Disc Herniation, Pregnancy, Cardiac Conditions.
- **■ Yellow Alert:** Joint/Knee instability, Carpal Tunnel, Post-Surgery recovery.
- Trainers can review past movement experience (**Beginner**, **Intermediate**, **Advanced**).

13.2 Attendance Marking Rules

At class completion, trainer marks each member:

- **completed:** Member trained. Credit permanently consumed.
- **no_show:** Member did not attend and failed to cancel.

- *Standard Rule:* Credit forfeited.

- *Medical / Emergency Waiver:* Trainer can check "Waive penalty" to restore credit if absence was justified.

14. Studio Admin Operations & Lead Conversion System

14.1 Registered Prospects & 1-Click Conversion (#/admin/prospects)

- Identifies registered accounts that have never bought a pass or whose passes expired without renewal.
- Displays full name, email, phone, and goals from their initial signup.
- **1-Click Grant:** Admin clicks "Grant Complimentary Pass":

- Provisions a single-session trial pass (**pkg-reformer-dropin**, validity 30 days).

- Logs audit record: "**Granted complimentary trial pass by admin**".

- Automatically moves user from "Prospect" to "Active Member".

14.2 Accounting & Financial Oversight (#/admin/payments)

- Comprehensive payments ledger displaying transaction reference, member name, base amount, CGST, SGST, total, status, and payment gateway timestamp.
- Deduplication algorithm automatically filters duplicate webhook retries to maintain 100% financial reconciliation.

15. Health Questionnaire, Medical Waivers & Safety Precautions

15.1 Health Questionnaire Schema

In **#/portal/profile**, members complete their health assessment:

- **hasCardiovascularCondition** (Boolean)
- **hasSpinalInjuryOrHerniation** (Boolean)
- **hasJointOrBoneIssue** (Boolean)
- **isPregnantOrPostnatal** (Boolean)
- **hasRecentSurgeries** (Boolean)
- **medicalNotes** (String)
- **emergencyContactName** (String)
- **emergencyContactPhone** (String)
- **emergencyContactRelation** (String)

15.2 Safety Flags & Studio Invariants

- Members with spinal herniations are flagged to avoid deep forward flexion on the Reformer carriage.

- Pregnant members are flagged for elevation wedge usage and forbidden from prone (face down) exercises after trimester 1.

16. Activity Audit Trail & Observability Infrastructure

The studio maintains an immutable audit log (**activity_logs**):

- **id**: Unique UUID
- **actor_id**: UUID of member, admin, or trainer performing the action
- **actor_role**: 'member' | 'admin' | 'trainer' | 'partner' | 'system'
- **category**:
 - **auth**: Logins, OTP dispatches, email changes, password resets.
 - **booking**: Bookings, cancellations, waitlist promotions, partner reviews.
 - **payment**: Orders created, signatures verified, passes activated.
 - **admin**: Complimentary passes granted, class schedules modified, price adjustments.
 - **profile**: Health profile updates, emergency contact modifications.
 - **action**: Human-readable summary (e.g., "Purchased 10 Classes Pass").
 - **metadata**: JSON payload containing context (session IDs, amounts, IP addresses).
 - **created_at**: ISO timestamp locked to IST.

17. Complete Backend API Endpoint Specification

All backend endpoints are hosted on **server.cjs** (:3333):

1. Configuration & Health

- **GET /api/public-config**: Returns { **supabaseUrl**, **supabaseAnonKey**, **razorpayKeyId** }.
- **GET /api/health**: Returns { **status**: 'healthy', **uptime**, **timestamp** }.

2. Authentication & Verification

- **POST /api/send-signup-otp**: Body { **fullName**, **email**, **phone**, **password**, **movementLevel** }.
- **POST /api/verify-signup-otp**: Body { **email**, **code**, **fullName**, **phone**, **password**, **movementLevel** }.
- **POST /api/request-email-change**: Body { **memberId**, **newEmail** }.
- **POST /api/verify-email-change**: Body { **memberId**, **newEmail**, **code** }.

3. Payments & Receipts

- **POST /api/create-razorpay-order**: Body { **packageId**, **notes** }. Returns { **orderId**, **amount**, **keyId** }.
- **POST /api/verify-and-fulfill-payment**: Body { **razorpay_order_id**, **razorpay_payment_id**, **razorpay_signature**, **packageId** }. Returns { **success**: true, **passId**, **invoiceNumber** }.
- **POST /api/webhooks/razorpay**: Razorpay server-to-server webhook callback.
- **GET /api/receipts/:orderId**: Returns compiled HTML Tax Invoice.

4. Studio Data Sync & Mutations

- **GET /api/classes:** Fetches active class sessions.
- **POST /api/classes:** Admin creates class session.
- **PUT /api/classes/:id:** Admin updates class session.
- **DELETE /api/classes/:id:** Admin cancels class session (triggers automatic member credit refunds).
- **GET /api/bookings:** Fetches bookings (scoped by role / user ID).
- **POST /api/bookings:** Books spot in class.
- **PUT /api/bookings/:id/cancel:** Cancels booking (evaluates 12h/6h window).
- **PUT /api/bookings/:id/attendance:** Trainer marks attendance (**completed** / **no_show**).
- **POST /api/partner/reviews:** Body { **bookingId**, **decision**: 'accept'|'decline', **reason** }.
- **POST /api/complimentary-pass:** Admin grants trial pass to prospect.
- **GET /api/activity-logs:** Admin fetches audit logs with category filters.

18. Complete Database Schema & Data Dictionary

```
-- 1. PROFILES (Users & Roles)
CREATE TABLE profiles (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  email VARCHAR(255) UNIQUE NOT NULL,
  full_name VARCHAR(255) NOT NULL,
  role VARCHAR(50) DEFAULT 'member' CHECK (role IN ('member', 'admin', 'trainer', 'partner')),
  phone VARCHAR(50),
  movement_level VARCHAR(50) DEFAULT 'Beginner',

  created_at TIMESTAMPTZ DEFAULT now(),
  updated_at TIMESTAMPTZ DEFAULT now()
);

-- 2. HEALTH PROFILES
CREATE TABLE health_profiles (
  user_id UUID PRIMARY KEY REFERENCES profiles(id) ON DELETE CASCADE,
  has_cardio BOOLEAN DEFAULT FALSE,

  has_spinal BOOLEAN DEFAULT FALSE,
  has_joint BOOLEAN DEFAULT FALSE,
  is_pregnant BOOLEAN DEFAULT FALSE,
  medical_notes TEXT,
  emergency_name VARCHAR(255),
  emergency_phone VARCHAR(50),
  updated_at TIMESTAMPTZ DEFAULT now()
);

-- 3. DISCIPLINES
CREATE TABLE disciplines (
  id VARCHAR(50) PRIMARY KEY,
  name VARCHAR(100) NOT NULL,
  description TEXT
);

-- 4. PACKAGES (Membership Products)
CREATE TABLE packages (
  id VARCHAR(100) PRIMARY KEY,
  name VARCHAR(255) NOT NULL,
  discipline_id VARCHAR(50),
  session_count INT NOT NULL,
  validity_days INT NOT NULL,
  price_inr NUMERIC(10, 2) NOT NULL,
```

```

    first_circle_price_inr NUMERIC(10, 2),
    first_circle_eligible BOOLEAN DEFAULT FALSE,
    is_active BOOLEAN DEFAULT TRUE,
    created_at TIMESTAMPTZ DEFAULT now()
);

-- 5. MEMBER PASSES (Purchased Entitlements)
CREATE TABLE member_passes (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID REFERENCES profiles(id) ON DELETE CASCADE,
    package_id VARCHAR(100) REFERENCES packages(id),
    status VARCHAR(50) DEFAULT 'active' CHECK (status IN ('active', 'completed', 'expired', 'paused')),
    is_trial BOOLEAN DEFAULT FALSE,
    purchased_at TIMESTAMPTZ DEFAULT now(),
    expires_at TIMESTAMPTZ NOT NULL
);

-- 6. MEMBER PASS CREDITS (Discipline Credit Buckets)
CREATE TABLE member_pass_credits (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    pass_id UUID REFERENCES member_passes(id) ON DELETE CASCADE,
    discipline_id VARCHAR(50) REFERENCES disciplines(id),
    total_credits INT NOT NULL,
    remaining_credits INT NOT NULL CHECK (remaining_credits >= 0)
);

-- 7. CLASS SESSIONS (Studio Timetable)
CREATE TABLE class_sessions (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    title VARCHAR(255) NOT NULL,
    discipline_id VARCHAR(50) REFERENCES disciplines(id),
    trainer_id UUID REFERENCES profiles(id),

    start_time TIMESTAMPTZ NOT NULL,
    duration_minutes INT DEFAULT 60,
    capacity INT DEFAULT 6 CHECK (capacity <= 6),
    spots_remaining INT DEFAULT 6 CHECK (spots_remaining >= 0 AND spots_remaining <= 6),
    status VARCHAR(50) DEFAULT 'scheduled' CHECK (status IN ('scheduled', 'cancelled', 'completed'))
);

-- 8. BOOKINGS
CREATE TABLE bookings (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    session_id UUID REFERENCES class_sessions(id) ON DELETE CASCADE,
    user_id UUID REFERENCES profiles(id) ON DELETE CASCADE,
    pass_id UUID REFERENCES member_passes(id),
    status VARCHAR(50) DEFAULT 'upcoming' CHECK (status IN ('upcoming', 'completed', 'cancelled', 'no_show', 'pending_partner_approval')),
    attendance VARCHAR(50),
    booked_at TIMESTAMPTZ DEFAULT now(),
    cancellation_reason VARCHAR(100)
);

-- 9. PAYMENTS (Financial Ledger)
CREATE TABLE payments (
    id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
    user_id UUID REFERENCES profiles(id),
    order_id VARCHAR(100) UNIQUE NOT NULL,

    payment_id VARCHAR(100) UNIQUE,
    amount NUMERIC(10, 2) NOT NULL,
    cgst NUMERIC(10, 2) NOT NULL,
    sgst NUMERIC(10, 2) NOT NULL,
    status VARCHAR(50) DEFAULT 'captured',
    invoice_number VARCHAR(100) UNIQUE NOT NULL,
    created_at TIMESTAMPTZ DEFAULT now()
);

```

```
-- 10. ACTIVITY LOGS (Audit Trail)
CREATE TABLE activity_logs (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID REFERENCES profiles(id),
  actor_role VARCHAR(50) NOT NULL,
  category VARCHAR(50) NOT NULL CHECK (category IN ('auth', 'booking', 'payment', 'admin', 'profile')),
  action TEXT NOT NULL,

  details JSONB,
  created_at TIMESTAMPTZ DEFAULT now()
);

-- 11. WAIVER ACCEPTANCES
CREATE TABLE waiver_acceptances (
  id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id UUID REFERENCES profiles(id) ON DELETE CASCADE,

  waiver_version VARCHAR(20) NOT NULL,
  accepted_at TIMESTAMPTZ DEFAULT now(),
  ip_address VARCHAR(100)
);
```

19. Edge Cases, Race Conditions & Failure Recovery Matrix

Scenario / Edge Case	Failure Mode / Threat	System Defense & Recovery Architecture
Simultaneous Last Spot Booking	2 members click "Book Spot" simultaneously when spotsRemaining == 1 .	Database transaction checks spotsRemaining > 0 before decrementing. Second transaction fails condition check and throws "Class fully booked" .
Browser Crash During Payment	Member's UPI succeeds but browser window is closed before returning to /cart .	Redundant server webhook (POST /api/webhooks/razorpay) receives payment.captured directly from Razorpay servers and executes fulfillVerifiedPayment() in background.
Duplicate Webhook Delivery	Razorpay resends same webhook event twice due to network delay.	Idempotency gate checks payments.order_id . Second execution detects existing payment record and returns HTTP 200 without creating a duplicate pass.
Midnight Class Cancellation	Class at 07:30 AM cancelled at 08:00 PM previous evening (11.5 hours prior).	Morning window requires 12h. Request rejected with HTTP 400 specifying 12-hour requirement. If member cancels anyway, spot is released but credit is forfeited.
Past Session Cancellation Attempt	Attacker calls PUT /api/bookings/:id/cancel on yesterday's completed session.	Checked against session.startTime < now() . Throws HTTP 400 "Concluded classes cannot be cancelled" .
Spots Exceeding Capacity Bug	Multiple cancellations increment spotsRemaining past studio capacity.	Enforced by invariant: spotsRemaining = Math.min(session.capacity, session.spotsRemaining + 1) . Value never exceeds 6.
Expired Barre Request	Partner forgets to review pending Barre session for 4 days.	Automated expiry engine checks now() - bookedAt > 48h . Cancels booking, restores credit to member, and frees class spot automatically.
Zero Credit Account Booking	Client-side script bypassed to book class with 0 credits.	Backend checks remaining_credits > 0 in database. Rejects with HTTP 400 "No remaining credits for discipline" .
Admin Privilege Escalation	Member modifies token payload to claim role = 'admin' .	Protected endpoints verify user role in database profiles table via Supabase Service Role key, ignoring client-tampered claims.
Cloud Disconnect / Supabase Down	Cloud provider outages or offline local dev.	In-memory fallback in store.js + seed-data.js keeps entire UI functional; changes persist to local fixtures in data/*.json .

20. Conclusion & Architectural Integrity

The Plash Pilates web platform represents an airtight, production-grade fitness management system. Every operational discipline—from boutique reformer capacity limits to Indian statutory GST tax splitting and cryptographic payment fulfillment—is enforced via strict mathematical invariants, defensive database constraints, and automated unit test assertions.